

ENTREGABLE 1

Análisis y planificación del Pentest

Caso Aurora Market

Realizado por	Deyra Salazar
Fecha	sept 2026

Objetivos del Pentest

Objetivo 1	Identificar si existen vulnerabilidades de seguridad en su aplicación que puedan causar explotación y se vea comprometida la CIA de la información o servicios.
Objetivo 2	Ver el nivel de seguridad a nivel de autenticación o control de accesos de los usuarios para confirmar si es posible que usuarios puedan ver datos de otros.
Objetivo 3	Determinar el nivel de riesgo de las vulnerabilidades encontradas y hacer las recomendaciones de remediación que permitan reducir la exposición y proteger los datos.

Alcance

Si se evaluará	● Aplicación web ● Forma de registro, log in, log out, cambio de password, de recuperación de cuentas. ● Como se gestiona las sesiones entre los usuarios y controles de autorización. ● Cual es el alcance de los usuarios en la aplicación: productos, carrito, consulta de información personal, de pagos, etc. ● Cuentas administrativas ● Endpoints y apis de uso de la aplicación.
No se evaluará	● Redes sociales de la empresa ● Correo electrónico empresarial y de empleados. ● Dispositivos como laptops o celulares de los empleados. ● Cuentas o sistemas de proveedores. ● Phising o ingeniería social. ● Ataques de DDoS ● Dominios o equipos o sistemas que no se encuentren autorizados de manera explicita.

Autorización y condiciones

Permisos requeridos	● Autorización formal y por escrito de la empresa Aurora para realizar el pentest. ● Identificación exacta de las Urls, dominios y sistemas autorizados por el cliente. ● Definición de las técnicas de pruebas permitidas y prohibidas. ● Cuentas y credenciales para hacer las pruebas para los diferentes perfiles. ● Autorización para realizar pruebas de vulnerabilidades y explotación controlada. ● Lista de contactos de emergencia de Aurora Market.
Condiciones acordadas	● Se debería acordar realizar las pruebas durante horarios no productivos o críticos. ● No se realizarán acciones que interrumpan los servicios de la plataforma. ● No se modificará ni se eliminará información de clientes. ● No se accederá a información que no sea necesaria para realizar la prueba. ● Si existe algún riesgo crítico o afectación de servicio se debe detener la prueba y notificar a los contactos de emergencias. ● Todas las evidencias deben almacenarse y se deben manejar de forma segura y confidencial.

Tipo de Pentest – Gray Box

Justificación	Debido a que se está recibiendo algo de información, se conoce que: ● Se sabe que existe una aplicación web. ● Se sabe que hay formas de autenticación. ● Que hay diferentes tipos de usuario. ● Se sabe que existe una base de datos. ● Se conoce el antecedente reportado por un usuario. Pero no se conoce la arquitectura, tecnologías, protección, código fuente ni configuraciones internas.
---------------	--

Planificación

Objetivos	● Identificar vulnerabilidades y determinar su impacto. ● Verificar los controles de autenticación y autorización.
Alcance	Aplicación web de Aurora Market y sus componentes (que estén expresamente autorizados).
Permisos y condiciones	Autorización escrita, pruebas controladas, horarios fuera de producción o fuera de horarios críticos, prohibición de afectar la información o disponibilidad del servicio.
Metodología	PTES. (Penetration Testing Execution Standard)
Recopilación de información previa	● URLs y dominios autorizados. ● Funcionalidades principales.

	● Tipos de usuario. ● Cuentas de prueba disponibles. ● Contactos técnicos. ● Horarios permitidos. ● Restricciones de las pruebas.
Recursos necesarios	● Equipo de pentesting. ● Navegador web. ● Proxy de análisis como Burp Suite u OWASP ZAP. ● Cuentas de prueba. ● Herramientas de reconocimiento y análisis web. ● Sistema seguro para almacenar evidencias.
Programación	Realizar las pruebas en las fechas autorizadas y preferentemente durante horarios de menor actividad, estableciendo ventanas para reconocimiento, análisis, validación y elaboración del informe.

Fases del Pentest

Reconocimiento	En esta fase se identificaría la superficie de ataque de la aplicación y se recopilaría la información sobre las tecnologías, funcionalidades, endpoints, parámetros, mecanismos de autenticación y tipos de usuario disponible. Para este caso: Registro → Login → Perfil → Productos → Carrito → Compra → Pedidos → Panel administrativo.
Análisis de vulnerabilidades	Analizaríamos las funcionalidades identificadas para detectar posibles vulnerabilidades de seguridad. Hay q revisar: ● autenticación ● gestión de sesiones ● autorización ● control de acceso ● validación de entradas ● exposición de información ● configuración de seguridad
Explotación	Se validaría de manera controlada las vulnerabilidades identificadas para comprobar si realmente pueden ser aprovechadas y determinar su impacto. Por ejemplo, si se sospecha de una vulnerabilidad de control de acceso, se podría utilizar dos cuentas de prueba autorizadas: Usuario A → solicita su pedido → se modifica el identificador → se intenta consultar pedido de Usuario B. Si la aplicación entrega información del usuario B, existiría evidencia de una falla de autorización. La explotación debe limitarse a demostrar la vulnerabilidad, evitando acceder o modificar datos reales innecesariamente.
Post-explotación	Se buscará determinar hasta dónde podría llegar un atacante después de explotar una vulnerabilidad, sin causar daño a la plataforma. Validar si la vulnerabilidad podría

	permitir: ● acceder a otros datos; ● aumentar privilegios; ● acceder a funciones administrativas; ● comprometer otras cuentas; ● exponer información sensible. Pero no se realizarían acciones destructivas. Por ejemplo: Vulnerabilidad → acceso no autorizado a pedidos → exposición de nombres/direcciones → posible afectación de múltiples clientes. Una vez demostrado el impacto, se detiene la prueba. No hace falta descargar miles de registros para demostrar que existe el riesgo.
Informe	Se debe documentar las vulnerabilidades encontradas, sus evidencias, nivel de riesgo, impacto para Aurora Market y recomendaciones para su corrección. Por cada hallazgo recomendaría incluir: Vulnerabilidad → Evidencia → Activo afectado → Impacto → Probabilidad → Severidad → Recomendación

Investigación

Metodología	PTES, debido a que establece una metodología que brinda una estructura para realizar la prueba de penetración. Define todas las fases desde la planificación hasta la elaboración del informe. Para este caso es muy útil porque como hemos desarrollado previamente, con esta metodología podemos definir antes de la prueba el alcance y las reglas de compromiso, recopilar información sobre la aplicación, identificar y analizar vulnerabilidades, validar su explotación de manera controlada, evaluar el impacto y finalmente documentar los riesgos y recomendaciones de seguridad.
-------------	---